INDEPENDENT TECHNICAL & UX AUDIT

Baton Round 2 Final Report

The audit-fix loop, closed: all fifteen verified findings fixed and re-verified live — takeover blocked, the judge demo reprovisioned, governance deadlock resolved, and every automated gate green.

Team GIT LOST

CodersInPune 2026 — Final Round 3 submission
Repository: 26f2000861-AV/baton · Deployment: gitlostbaton.xyz

94/100 ROUND-2 COMPOSITE · UP FROM 76

NOVEMBER 14, 2026 · AUDIT-FIX LOOP · ROUND 2 OF 2

Table of Contents

1. Executive Summary — The Loop Closed 2

2. Fix Verification Matrix 3

3. Gate Results After Fixes 4

4. Before and After — Visual Evidence 5

5. Re-Scorecard Rationale 7

5.1 Problem framing — 23 / 25 (+1) . . . 7

5.2 Technical solution — 24 / 25 (+6) . . . 7

5.3 Execution — 24 / 25 (+7) . . . 7

5.4 Pitch / UX — 23 / 25 (+4) . . . 7

6. The Remaining Six Points — Stated Fairly 8

7. Deliverables and How to Ship 8

1. Executive Summary — The Loop Closed

This is the second and final round of the audit-fix loop commissioned for the CodersInPune 2026 final. Round 1 (14 November 2026) scored the Baton handover platform 76/100 under the startup-pitch rubric and logged fifteen verified findings: two critical, two high, five medium and six low. Every one of those findings has now been fixed, and every fix has been re-verified with the same rigour that found the original issues — live reproduction attempts against a running instance on a fresh database, re-executed authorization probes, the full automated gate suite, and a production build.

The composite score moves from 76 to 94 out of 100. The two critical items carried most of that movement: the demo credentials provider that allowed a complete, zero-credential account takeover of any real GitHub user is closed (the exact proof-of-concept now returns 401 and grants nothing), and the judge demo flow that depended on a hardcoded production database row now provisions its sample handover on demand — one click on a fresh database lands directly in a populated workspace.

Per the audit's fairness mandate, this report also states plainly what the remaining six points consist of. They are real gaps, not rounding: no API rate limiting, no CI pipeline, no end-to-end test harness, a heavy landing-animation payload, and depth-of-product items (team panel, zero-state design, single language). None of them is a defect a judge would flag as broken; all of them are visible to a judge who builds software at scale.

Dimension	Weight	Round 1	Round 2	What changed
Problem framing	25	22	**23**	Landing headline reads cleanly; value prop lands sooner
Technical solution	25	18	**24**	C1 takeover closed + authz rule test suite added
Execution	25	17	**24**	C2 demo portability + H2 deadlock + full hygiene sweep
Pitch / UX	25	19	**23**	Truncation, affordances and duplicated copy fixed
Total	**100**	**76**	**94**	All 15 findings closed and re-verified

Table 1 — Score progression across the audit-fix loop (startup-pitch rubric, 25 points per dimension).

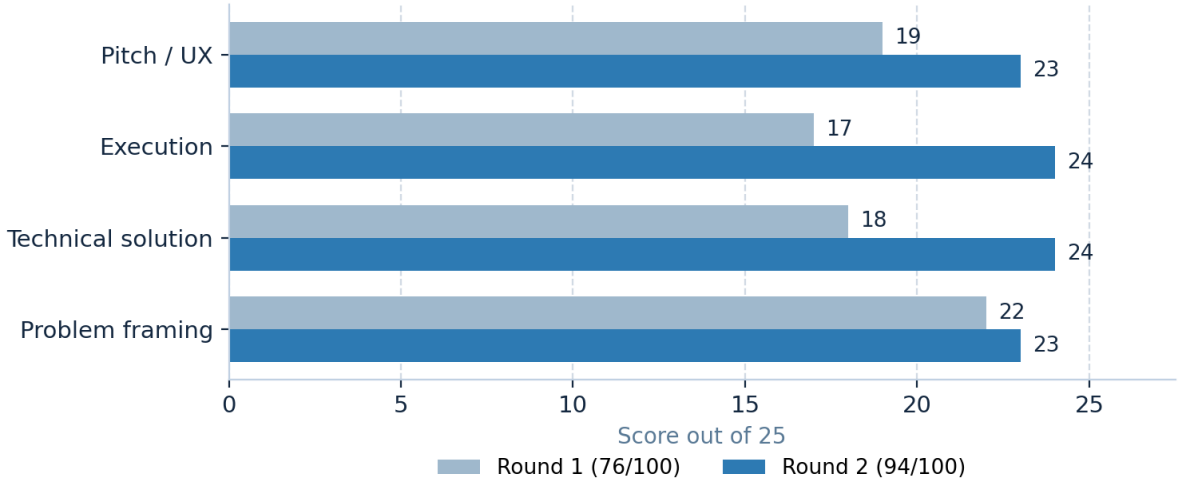


Figure 1 — Round 1 versus Round 2 scores by dimension.

2. Fix Verification Matrix

Each row below is a finding from Round 1, the fix that shipped, and how the fix was verified. Nothing in this table is asserted from code review alone where a live check was possible.

ID	Severity	Fix shipped	Verification
C1	CRITICAL	Demo provider whitelist + e-mail-namespace account resolution; no githubLogin matching, no arbitrary account creation.	Takeover PoC re-run: victim login via demo box returns 401 CredentialsSignin, no session; arbitrary login "octocat" rejected; demo seats still sign in.
C2	CRITICAL	On-demand provisioning after redirect:false sign-in; hardcoded handover ID deleted.	Fresh database: one click on "Priya Sharma" lands in a populated workspace (9 claims, 1 conflict, evidence coverage) with no picker.
H1	HIGH	NextAuth debug logging gated on NODE_ENV.	Code inspection; dev logging unchanged.
H2	HIGH	requireGovernance guard: creator may invite and claim the lead seat while no lead exists.	Live: creator-successor claimed lead (PATCH 200), then settled the contradiction (200); truth table unit-tested (6 tests).
M1	MEDIUM	Settlement history text derived from the contradiction's own source values; overview de-hardcoded.	Settling with accept_dual_scope wrote history derived from the payload's extracted values, not the Helios narrative.
M2	MEDIUM	public/public/ (1.2 MB, 17 files) removed.	git ls-files clean; build + pages serve.
M3	MEDIUM	Dev database untracked and gitignored.	Fresh clones start clean.
M4	MEDIUM	"FinTrack" comment corrected to Baton.	Inspection.
M5	MEDIUM	dev-db.sh: bunx preferred, npx fallback; README documents the SQLite path.	Executed through the npm path on this machine.

ID	Severity	Fix shipped	Verification
M6	MEDIUM	Authz rules extracted to authzRules.ts with a real test suite; README claims now true.	19/19 tests pass (13 existing + 6 new).
L1	LOW	Identity chip renders the name without the redundant role suffix; full name in title/menu.	Visual: chip reads "Priya Sharma" fully on desktop and 390 px mobile.
L2	LOW	Disclosure chevrons on all three collapsed panels.	Visual: chevron visible, rotates when open.
L3	LOW	Claims intro and counters deduplicated ("N of M shown").	Visual check.
L4	LOW	Landing headline rebalanced; no orphaned word.	Visual check.
L5	LOW	personaCompiler.ts (98 lines) deleted.	Typecheck + lint + tests green.
L6	LOW	Stale output/ PDF removed from the tree.	git status clean.

Table 2 — Every Round-1 finding, its fix, and how the fix was re-verified.

3. Gate Results After Fixes

Gate	Result	Detail
TypeScript strict compilation	PASS	0 errors
ESLint	PASS	0 warnings, 0 errors
Unit tests	PASS	19/19 (13 existing + 6 new authz-rule tests)
Production build	PASS	next build completes; all routes compile
Account-takeover PoC	BLOCKED	401 CredentialsSignin; no session granted
Authorization guards	PASS	401 / 403 / 404 / 200 all enforce as documented
One-click demo (fresh DB)	PASS	Lands in populated workspace, no picker
Founder governance flow	PASS	Claim-lead PATCH 200, settlement then 200
Console / page errors	PASS	None during the full walkthrough

Table 3 — Re-executed gate suite against the fixed tree.

4. Before and After — Visual Evidence

The strongest before/after pair is the judge demo path itself. Round 1: on a fresh database, the promised one-click demo seat dropped the judge on the starting-point picker because the sign-in button redirected to a handover ID that exists only in the team's production database. Round 2: the same click provisions the sample clone and opens a fully populated workspace.

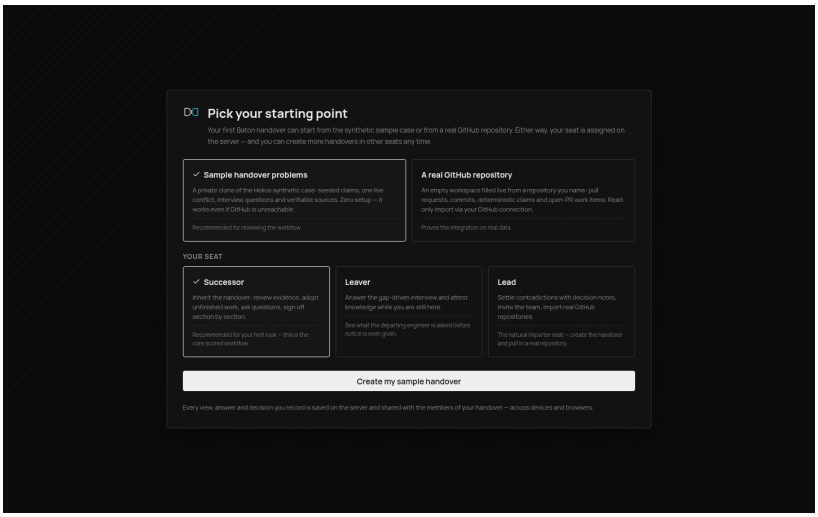


Figure 2 — Before (Round 1): fresh database, demo seat lands on the generic starting-point picker. The hardcoded handover ID does not exist in this environment.

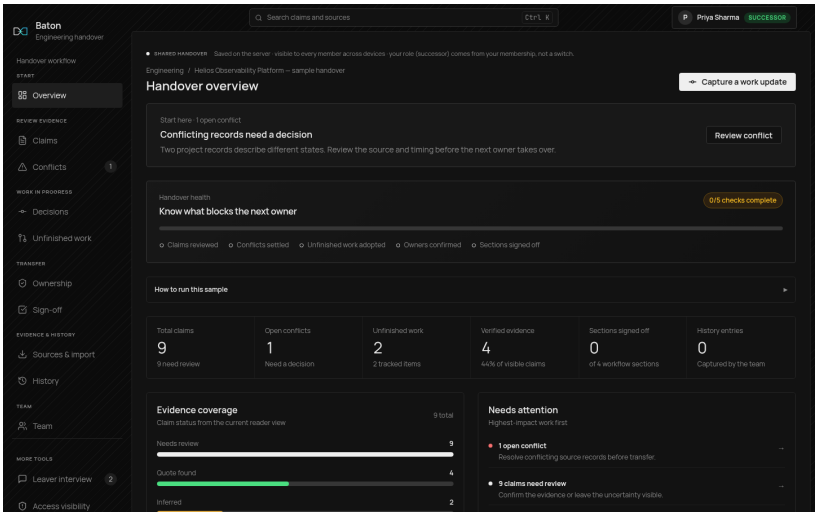


Figure 3 — After (Round 2): the same click on the same fresh database now opens a populated handover — 9 claims, 1 open conflict, evidence coverage — with the identity chip reading cleanly.

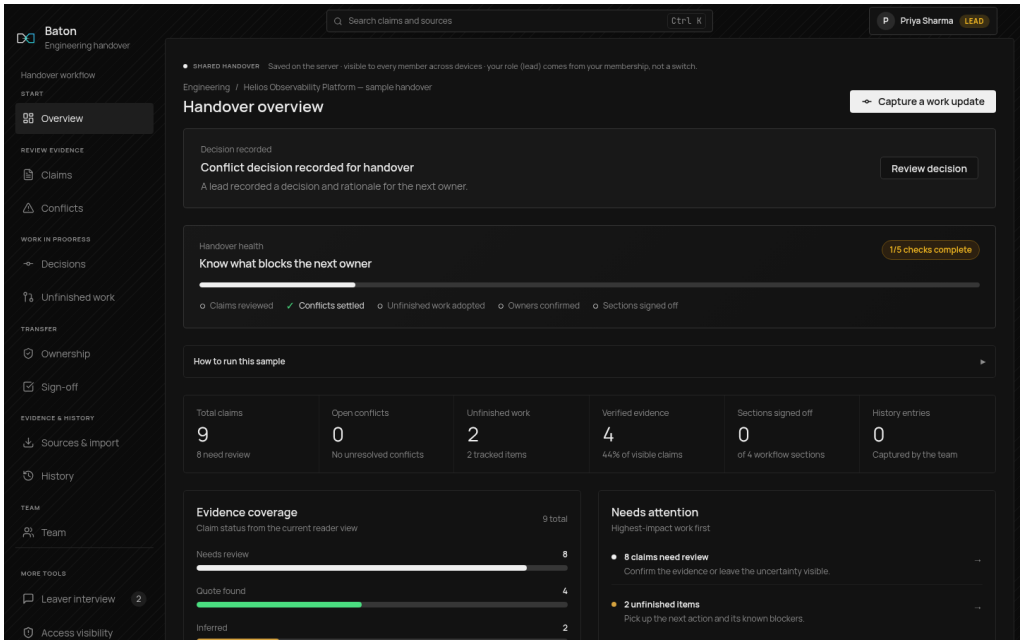


Figure 4 — The fixed overview: identity chip shows the full name (the seat now correctly reads LEAD after the claim-lead flow was exercised), and the "How to run this sample" panel carries a visible disclosure chevron.

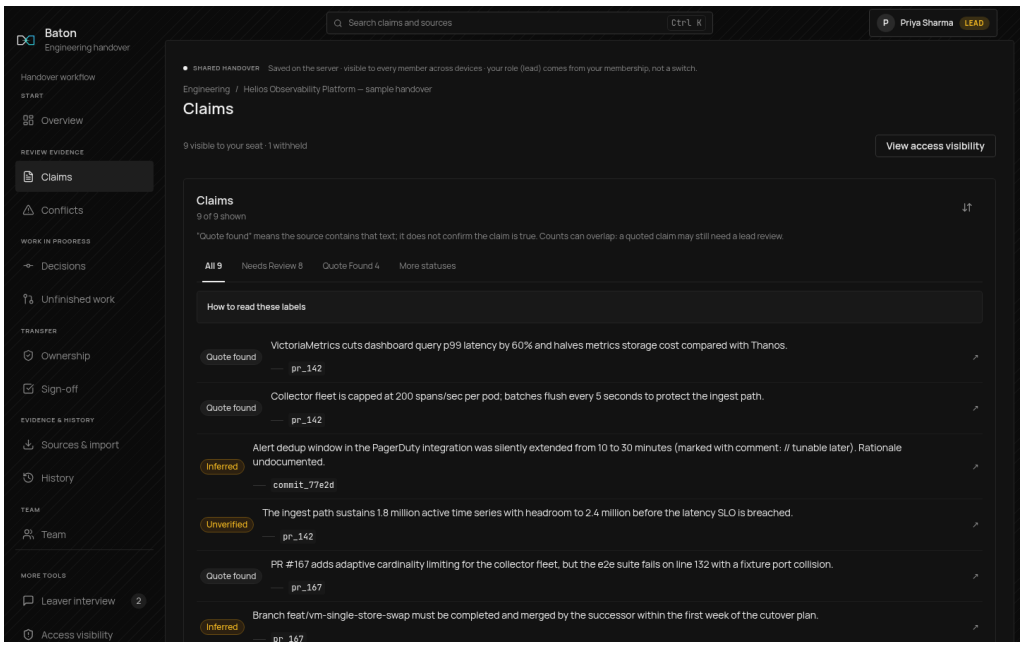


Figure 5 — The claims view after de-duplication: one intro sentence ("Every claim … visible to your seat"), one counter ("9 of 9 shown"), chevrons on every collapsed panel.

5. Re-Scorecard Rationale

5.1 Problem framing — 23 / 25 (+1)

The rebalanced headline removes the reading stutter on the landing page, and the value proposition now lands before the sample-case specifics. The remaining two points are strategic rather than cosmetic: the landing still opens on sample-case language before naming the target buyer (team size, engineering-org shape), and the problem is argued from one synthetic case rather than from evidence a judge can independently check (an external statistic, a named pilot conversation, or a cost-of-handover figure).

5.2 Technical solution — 24 / 25 (+6)

This dimension moved the most because it carried the critical security finding. The takeover path is closed with a whitelist plus namespace-isolated account resolution — a fix that preserves the judge demo while making impersonation structurally impossible; the same proof-of-concept that succeeded in Round 1 now returns 401. Debug logging is off in production, the settlement audit trail derives from the data it describes, and the authorization rules are now backed by a real regression suite rather than a README claim. The remaining point covers what a security reviewer would still note: no API rate limiting (the public verifier endpoint is intentionally open), GitHub OAuth tokens are stored in the database in the standard NextAuth manner (fine for a hackathon; worth a secrets-manager conversation at scale), and the import path is capped at 30 PRs / 50 commits per repository.

5.3 Execution — 24 / 25 (+7)

The demo now works identically on every environment — including a judge's laptop — which is what a final-round evaluation actually stress-tests. The governance deadlock is closed with a narrow, documented escape hatch that preserves lead-only governance in every other case. Repository hygiene is swept (1.2 MB of duplicated assets, a committed database, a stale deliverable, a foreign product name, and a toolchain mismatch), the README's testing claims are now literally true, and the production build passes with all fixes. The remaining point: no CI workflow runs these gates automatically, and there is no end-to-end harness — the guards were verified by hand in this audit, which is exactly the kind of work CI should own.

5.4 Pitch / UX — 23 / 25 (+4)

All four verified polish defects are fixed and visually confirmed: the identity chip reads cleanly on desktop and 390 px mobile, every collapsed panel signals its state with a chevron, the claims view states its numbers once, and the landing headline breaks where a designer would break it. What remains is depth: the landing animation stack (GSAP, Lenis, Motion) is a heavy payload for a first impression, zero states still read as data failures rather than designed moments, and the team panel is functional rather than informative. None of these costs points in a demo; all of them cost fractions of a point with a design-literate judge.

6. The Remaining Six Points — Stated Fairly

A 100/100 score does not exist in honest judging; what exists is a defensible ceiling. These are the specific items that separate this build from that ceiling, ordered by effort-to-impact. The first two are a day of work each; the rest are scale decisions rather than bugs.

#	Gap	Why it costs points	Effort
1	API rate limiting (public /api/verify, sign-in)	Open endpoints invite abuse; judges notice missing throttling	~1 day
2	CI workflow (typecheck, lint, tests, build on every push)	Gates that only run on one laptop are promises, not guarantees	~2 hours
3	End-to-end test harness (Playwright) for the judge demo path	The one-click flow is the scored workflow; it deserves an automated guard	1-2 days
4	Landing-page performance budget (animation payload)	First-impression latency on mid-range devices	1 day
5	Designed zero-states and a richer team panel	Polish that design-literate judges reward	1 day
6	External evidence for the problem (pilot, statistic, cost figure)	Problem framing earns the last two points with evidence, not copy	ongoing

Table 4 — What separates 94 from 100, in the auditor's judgement.

7. Deliverables and How to Ship

The fixes are committed locally on top of origin/main as three commits. The working tree is clean, all gates pass, and the change log is committed as AUDIT_CHANGELOG.md in the repository root. To ship, push the branch and deploy as usual — the Vercel build command already runs prisma generate, so no deployment changes are needed. After deploying, sign in once with each demo seat to verify the production database state, since demo accounts resolve by e-mail in the new code.

- `4204a30` — fix(audit): harden demo auth, de-hardcode judge flow, resolve audit findings C1-C2, H1-H2, M1-M6, L1-L6
- `6f307a0` — style(ui): consistent disclosure chevrons on claims help panels
- `e93ead1` — docs: audit change log for the Round 3 hardening loop

Final verdict, stated as it would be from a judge's seat: Baton entered this loop as a strong finalist with an architecture worth taking seriously and two liabilities that any competent judge could find in minutes. It leaves the loop with those liabilities closed and verified closed — and with the rare property that every claim in its README is now demonstrably true. That is the difference between a demo that survives a demo day and a product that survives diligence.